

TAXONOMÍA, CICLO DE VIDA Y ARQUITECTURA CORRELATIVA DE DATOS

ENTIDAD: Neobank Digital, S.A.
MÓDULO 1: Política de Privacidad y Tratamiento de Datos
ENTREGABLE 1.2: Taxonomía y Arquitectura de Datos (Documento 2 de 3)
VERSIÓN: 4.2.0-PROD
CLASIFICACIÓN: Estrictamente Confidencial / Secreto Corporativo

CAPÍTULO I: MODELADO DE PERSISTENCIA Y GOBERNANZA DE ENTIDADES DE CORE BANCARIO

1.1. Estrategia de Persistencia Polígota y Segregación Estructural

Neobank Digital, S.A. fundamenta su infraestructura transaccional en un paradigma de persistencia polígota, donde cada dominio de datos es asignado a un motor de base de datos específico atendiendo a sus requerimientos de consistencia, disponibilidad, particionamiento y modelo de datos. El Core Bancario Central utiliza un modelo relacional estricto basado en PostgreSQL Enterprise, configurado bajo el principio de aislamiento ACID (Atomicidad, Consistencia, Aislamiento, Durabilidad) para gestionar los balances, ledgers contables y saldos transaccionales de los clientes. Este entorno relacional prohíbe el uso de esquemas dinámicos y delega la integridad referencial de forma mandatoria a nivel de motor mediante llaves foráneas estrictas y restricciones check.

De forma paralela, el almacenamiento de metadatos de conectividad, telemetría de la infraestructura móvil y logs de auditoría conductual se delega a clústeres no relacionales (NoSQL) optimizados para escrituras masivas concurrentes y persistencia documental. Los esquemas relacionales mapean las entidades críticas de identidad mediante identificadores únicos universales (UUIDv4) aleatorios e independientes, eliminando cualquier correlación secuencial predecible que pueda facilitar ataques de enumeración de recursos u horizontales de control de accesos (IDOR).

1.2. Diccionario Maestro de Esquemas de Persistencia (Esquema SQL/NoSQL)

Para asegurar la inmutabilidad y legibilidad forense de la información, el diseño de la base de datos maestra de Neobank Digital prohíbe modificaciones manuales sobre las estructuras de datos (Data Definition Language - DDL). Todo cambio estructural debe ser inyectado mediante scripts de migración versionados controlados por canalizaciones DevSecOps automatizadas. Las tablas core destinadas a almacenar registros identificables directos e indirectos incorporan metadatos ocultos de control perimetral, incluyendo marcas de tiempo con precisión de microsegundos, firmas de verificación criptográfica por fila (Row Hash Verification) e identificadores de servicios autorizados.

Los sistemas de almacenamiento documental gestionan objetos binarios grandes (BLOBs), tales como imágenes digitalizadas de identificaciones oficiales y firmas autógrafas digitalizadas, en repositorios de almacenamiento de objetos aislados de la red pública. El acceso a estas estructuras desde las bases de datos relacionales se realiza únicamente mediante la persistencia de punteros lógicos URI firmados y temporales con tokens de acceso efímeros que expiran de manera automatizada tras trescientos (300) segundos de su emisión.

CAPÍTULO II: MATRIZ AVANZADA DE CLASIFICACIÓN DE DATOS Y ESQUEMA DE ALMACENAMIENTO

2.1. Taxonomía de Atributos de Identidad y Transaccionalidad

Cada campo admitido por el ecosistema API de la Entidad se encuentra rigurosamente indexado dentro del Catálogo Corporativo de Atributos de Datos. Está prohibida la adición de propiedades "libres" o "genéricas" en los cuerpos JSON de las APIs o en las columnas de las bases de datos. La siguiente matriz detalla de manera forense la distribución técnica, almacenamiento y técnicas específicas de protección aplicadas a los campos nucleares del sistema financiero de Neobank Digital:

Categoría de Dato	Campos Específicos (Payload / DB)	Motor de Persistencia	Estrategia de Cifrado y Anonimización	Plazo de Retención Activa
Datos Identificables Directos (DID)	Nombre, Apellidos, Código Único de Identificación (CUI), NIT, Correo Electrónico.	PostgreSQL Core Relacional (Tablas Enmascaradas).	Cifrado Homomórfico a nivel de columna (AES-GCM-256) administrado por HSM. Enmascaramiento dinámico en API Gateway.	Duración de la relación contractual más 5 años post-cierre (Requerimiento SIB/IVE).
Datos Biométricos Sensibles (DBS)	Mapas de vectores tridimensionales de geometría facial, minucias de huellas dactilares.	Base de Datos de Vectores Criptográficos Aislada (Análisis de Grafos).	Salting y Hashing irreversible mediante algoritmos robustos con funciones de derivación de llaves (Argon2id / PBKDF2).	Destrucción automática en 48 horas tras fallar validación o al cerrar la cuenta de forma definitiva.
Metadatos de Infraestructura (MIT)	UUID de dispositivo, IMEI, Dirección MAC, IPs de conexión, Coordenadas GPS Satelitales.	NoSQL Orientado a Documentos (Clúster Shardeado).	Cifrado en reposo del volumen lógico de almacenamiento (XTS-AES-256). Seudonimización con hashes rotativos de ID.	24 meses continuos para análisis forense, prevención de fraudes y auditoría perimetral.
Datos Financieros Operativos (DFO)	Número PAN de Tarjeta (Tokenizado), Balances de Cuentas, Historial Transaccional ISO 8583.	PostgreSQL Core Transaccional + Ledger Inmutable Interno.	Tokenización PCI-DSS. Los balances se firman con HMAC-SHA-256 encadenado secuencialmente al bloque previo.	10 años conforme al Código de Comercio de la República de Guatemala.

CAPÍTULO III: MAPEO TÉCNICO DE LOS FLUJOS DE CAPTURA Y PROCESAMIENTO DE IDENTIDAD

3.1. Pipeline de Ingesta Digital de Datos de Identificación Colectiva

El flujo de captura de datos personales de identidad de Neobank Digital se ejecuta mediante una tubería de software asíncrona y blindada (Zero-Trust Data Ingestion Pipeline). Cuando un usuario ingresa sus datos demográficos e imágenes de documentos desde la app móvil, el cliente móvil cifra el payload en memoria utilizando una llave pública asimétrica RSA-4096 perteneciente exclusivamente al clúster perimetral de descifrado seguro de la Entidad. Este paquete viaja sobre un canal TLS 1.3 forzado mediante directivas HSTS rígidas, lo que neutraliza cualquier vector de ataque de interceptación de tráfico (Man-in-the-Middle) en redes públicas o de telecomunicaciones.

Al ingresar al backend, los datos no tocan discos de almacenamiento intermedio comunes. El API Gateway redirige el flujo de forma exclusiva hacia un microservicio aislado de deserialización que opera en memoria RAM volátil protegida (Secure Enclaves / AMD SEV). Este microservicio valida la estructura formal del DPI mediante expresiones regulares y reglas de negocio, extrae el CUI y de inmediato invoca un proceso secundario que se conecta a través de un túnel IPsec privado con los servidores del Registro Nacional de las Personas (RENAP). El resultado de la verificación se almacena junto con el estatus del cliente, descartando de inmediato cualquier réplica de datos de filiación que exceda lo autorizado explícitamente por el usuario.

3.2. Procesamiento Inteligente de Biometría y "Prueba de Vida"

El tratamiento de datos biométricos sensibles representa el nivel de riesgo más alto dentro de la taxonomía de la plataforma. El proceso se inicia con la captura de un flujo de video en alta definición por parte de la cámara del usuario. El SDK móvil de Neobank analiza localmente parámetros de micro-movimiento facial, parpadeo y profundidad (Liveness Detection passive & active) para garantizar que el emisor de los datos es un ser humano vivo y presente en tiempo real, bloqueando ataques de suplantación basados en fotografías impresas, máscaras o pantallas de alta resolución.

Una vez confirmada la validez física del flujo, el cuadro óptico óptimo se procesa mediante un algoritmo extractor de características que transforma los rasgos de la cara en un vector matemático tridimensional abstracto compuesto por puntos flotantes ordenados. Este vector matemático es el único elemento que se transmite al servidor central; la fotografía original del rostro del cliente es destruida de la memoria caché del dispositivo móvil de forma inmediata. Al llegar al backend biométrico, el vector facial es sometido a un algoritmo de dispersión criptográfica irreversible con un valor de sal (Salt) dinámico por usuario, imposibilitando la ingeniería inversa que pretenda reconstruir el rostro humano a partir de la firma matemática almacenada.

CAPÍTULO IV: CICLO DE VIDA DEL DATO FINANCIERO Y GOBERNANZA DEL ALMACENAMIENTO

4.1. Fases Operativas del Ciclo de Vida del Dato en Neobank Digital

La Gobernanza Corporativa de Datos de Neobank Digital define de forma taxativa cinco fases cronológicas e institucionales para el tratamiento de la información, asociando cada etapa con restricciones físicas específicas a nivel de infraestructura de redes y almacenamiento:

Fase 1: Recolección Lícita y Validación: Fase de captura inicial donde se verifica la legitimidad de las fuentes de información, la integridad del consentimiento firmado digitalmente y la concordancia de los datos ingresados con los sistemas nacionales (RENAP/SAT). Los datos ingresados se marcan con el estatus operativo *PENDIENTE_DE_APROBACIÓN* y se confinan a zonas de red DMZ encriptadas.

Fase 2: Procesamiento Activo y Disponibilidad en Caliente: Una vez aprobada la cuenta, los datos ingresan a las bases de datos de producción con replicación síncrona en clústeres multi-región. Los microservicios financieros interactúan de forma constante con los datos transaccionales, saldos y tokens de sesión sobre redes privadas aisladas del exterior por cortafuegos de aplicaciones (WAF) y políticas rígidas de control de acceso de red (Network Security Groups).

Fase 3: Almacenamiento Pasivo y Retención por Cumplimiento (Warm Storage): Al cumplirse veinticuatro (24) meses desde la última actividad transaccional o tras la solicitud formal de cierre de cuenta por parte del cliente, los datos pasan automáticamente a un estado de congelamiento técnico. Son extraídos de las bases de datos relacionales de alta velocidad y transferidos a volúmenes de almacenamiento desacoplados de los entornos de ejecución diaria. En esta fase, los datos se encuentran enmascarados para el personal ordinario y solo son accesibles ante solicitudes formales emitidas por el Oficial de Cumplimiento de la SIB o mandatos judiciales.

Fase 4: Archivado de Seguridad en Frío (Cold Storage): Transcurridos los plazos de retención activa dictados por la normativa de prevención de lavado de dinero de la IVE, la información financiera consolidada y trazas de auditoría de cuentas cerradas son empaquetadas en archivos binarios fuertemente cifrados con algoritmos AES-256 de nivel militar. Estos paquetes se transfieren a sistemas de archivado en la nube de ultra-baja frecuencia de acceso (Object Storage Archive / Glacier), configurados bajo políticas rígidas de inmutabilidad física (Object Lock en modo Compliance), lo que impide que cualquier usuario, incluidos los administradores globales de infraestructura de la nube, altere o elimine los archivos hasta que expire el plazo legal completo de diez (10) años dictado por el Código de Comercio de Guatemala.

Fase 5: Destrucción Forense y Purga Criptográfica (Sanitization): Al cumplirse la expiración exacta de los plazos de retención legal obligatoria, el sistema de gobernanza automatizado activa el protocolo de destrucción forense. Para los entornos virtuales y bases de datos activas, se aplica el método de desintegración criptográfica, el cual consiste en la eliminación irreversible de las llaves de cifrado específicas de la fila o del usuario custodiadas en el HSM; sin la llave de descifrado, los datos binarios residuales en los discos magnéticos se transforman de forma matemática en ruido blanco térmico, un estado de entropía pura imposible de revertir mediante técnicas de recuperación forense digital conocidos. Para los respaldos en cinta física o discos locales de almacenamiento heredados, se ordena el borrado físico mediante algoritmos de sobrescritura multinivel que cumplen estrictamente con la norma internacional **NIST SP 800-88 Rev. 1 (Guidelines for Media Sanitization)**.

CAPÍTULO V: PROTOCOLO TÉCNICO DE ATENCIÓN DE INCIDENTES Y FUGAS DE INFORMACIÓN

5.1. Detección Temprana y Clasificación de Brechas de Seguridad

El Centro de Operaciones de Seguridad (SOC) de Neobank Digital mantiene herramientas automatizadas de Monitoreo de Pérdida de Datos (DLP - Data Loss Prevention) que analizan en tiempo real los patrones de salida de información en todas las capas de la red. Se define un Incidente de Privacidad de Datos como cualquier evento confirmado que provoque la destrucción, pérdida, alteración accidental o ilícita, o la comunicación o acceso no autorizado a datos personales transmitidos, conservados o tratados por la Entidad.

Ante la activación de una alerta de DLP, el equipo de Respuesta a Incidentes de Ciberseguridad (CSIRT) clasifica la brecha bajo una escala tridimensional de impacto:

- **Severidad Alta (Crítica):** Exposición de Datos Biométricos Sensibles, credenciales de autenticación en texto claro o saldos consolidados de Core Bancario que comprometan la continuidad operativa.
- **Severidad Media:** Filtración de metadatos de infraestructura, identificadores de dispositivos o historiales transaccionales aislados sin asociación directa con el nombre o documento de identidad del usuario.

- **Severidad Baja:** Desalineación formal en los logs de acceso, trazas de depuración de software que expongan datos internos del sistema sin afectación directa a la privacidad de datos de los cuentahabientes.

5.2. Aislamiento Técnico de la Infraestructura y Contención

Confirmado un incidente de Severidad Alta, el Oficial de Seguridad de la Información (CISO) activa el protocolo de aislamiento perimetral automatizado mediante scripts de infraestructura como código (IaC). El primer paso consiste en la revocación inmediata de todas las llaves de acceso de API (API Tokens) y credenciales de IAM asociadas al segmento de red o servicio comprometido. Si el vector de ataque se localiza en un microservicio de base de datos específico, se activa una regla de firewall a nivel de kernel que deniega todas las conexiones de red entrantes y salientes (Network Isolation), desviando las llamadas del API Gateway a un clúster de contingencia precargado con datos seudonimizados de prueba para evitar la denegación total del servicio financiero.

Simultáneamente, se realiza una instantánea de memoria (RAM Dump) y un clon lógico encriptado de los discos virtuales afectados para preservar la evidencia digital en su estado nativo antes de ejecutar cualquier acción de limpieza. Este procedimiento de cadena de custodia digital sigue las directrices internacionales de la norma ****ISO/IEC 27037****. Una vez aislada la infraestructura comprometida, los ingenieros de SRE despliegan una versión limpia y auditada de los microservicios afectados utilizando contenedores Docker inmutables cuyos hashes criptográficos SHA-256 han sido previamente validados en el repositorio seguro de DevSecOps.

5.3. Plan de Comunicación Regulatoria y Notificación Obligatoria

En estricto cumplimiento de los estándares internacionales incorporados de manera cruzada (GDPR Artículo 33 y directrices de la ANPD de la LGPD), Neobank Digital se obliga legalmente a notificar de forma transparente la existencia de la brecha de seguridad a las autoridades regulatorias competentes nacionales e internacionales dentro de un plazo perentorio que no excederá de ****setenta y dos (72) horas**** contadas a partir de que la Entidad tenga conocimiento fehaciente del suceso.

El informe de notificación oficial, redactado y firmado por el Encargado de Protección de Datos (DPO) y el Asesor Legal Principal, debe contener con carácter obligatorio el siguiente contenido estructurado:

1. Descripción detallada de la naturaleza de la brecha de seguridad de los datos personales, incluyendo, de ser posible, las categorías y el número aproximado de interesados afectados, así como las categorías y el número aproximado de registros de datos personales afectados.
2. Nombre y los datos de contacto del Delegado de Protección de Datos o de otro punto de contacto en el que pueda obtenerse más información detallada.
3. Descripción de las consecuencias posibles e inferidas técnicamente de la brecha de seguridad de los datos.
4. Descripción de las medidas adoptadas o propuestas por Neobank Digital para poner remedio a la brecha de seguridad, incluidas las medidas adoptadas para mitigar los posibles efectos negativos sobre los usuarios.

Cuando sea probable que la vulneración de la seguridad de los datos entrañe un alto riesgo para los derechos y libertades de los usuarios financieros, Neobank Digital comunicará de forma inmediata la brecha de seguridad al interesado en un lenguaje claro y sencillo a través de notificaciones push prioritarias dentro de la aplicación móvil y mediante correo electrónico certificado, indicando las acciones inmediatas que el usuario debe realizar, tales como la renovación de credenciales de acceso o la revocación manual de tokens de sesión activos en dispositivos de terceros.